

Penetration testing is mainly required for:

- Transferring financial or such critical data between different systems or over the network.
- To protect user data.
- To detect security weaknesses in an application.
- To discover defects in the system.
- To assess the losses due to cyber attacks and their impact on business.
- To meet the information security standards in the organisation.
- To bring into action an effective network security system in the organisation.

According to Hacken, the average cost of a penetration test can vary from US\$ 4,000 to US\$ 100,000. By using various methodologies to prevent advanced attacks, pen testing can identify SQL injections, cross-site scripting, low frequency interface (LFI), radio frequency interface (RFI) and other defects in the organisation's Web applications and infrastructure.

Companies that carry out penetration testing

Automated tools can be used to identify some standard threats present in an application. Pen test tools can scan code to check if there is a malicious code present that can lead to potential security threats.

Science Soft is a recognised IT consulting and software development pioneer in cyber security services. The company has more than 16 years of experience in conducting black box, white box and grey box penetration testing of all the IT infrastructure components.

Geneva based software company ImmuniWeb has DevSecOps-enabled application penetration testing platforms. It offers comprehensive application penetration testing of internal and external Web and mobile apps, APIs and Web services, mail servers, IoT devices, and more.

Types of pen testing

Social engineering test: This test is done to protect personal sensitive information like passwords, business critical data, etc. This is done for phone, Internet or helpdesk processes. Sensitive information may be leaked in email or phone communications. Cyber hackers may take the benefit of this. Security audits can be conducted to identify and correct such process defects.

Web application test: This is concerned with testing Web applications.

Physical penetration test: This test is generally used in military and government facilities. All physical network devices and access points are tested for any security breach.

Network services test: This is concerned with testing services offered by a network.

Client side test: This tests client side servers, computers, laptops, and various other devices.

Remote dial-up test: This searches for modems in the environment, and tries to log into the systems connected through these modems by password guessing or brute-forcing.

Wireless security test: This is concerned with detecting open, unauthorised and less secure hotspots or Wi-Fi networks.

Penetration testing comprises three parts.

Black box penetration testing: In this methodology, the tester assesses the target system, network or process without the knowledge of its details. No code is examined in this method.

White box penetration testing: In this approach, the tester is equipped with complete details about the target environment — systems, network, OS, IP address, source code, schemes, etc. It examines the code and finds out design and development errors. It is a simulation of an internal security attack.

Grey box penetration testing: Here, the tester has limited details about the target environment. It is a simulation of external security attacks.

Tools used in pen testing

Given below are the top tools used by pen testing teams worldwide.

The Network Mapper (also known as NMAP): This free tool is used mainly for discovering any kind of weakness or holes in the network environment of a system. Here, you can create a virtual map of the network segment, and then detect major areas of weaknesses that cyber attackers can penetrate through without any difficulty. It comes in both command and GUI formats.

Metasploit: This is a package of different pen testing tools. It is powered by the Perl platform and comes with built-in customisable exploits that can be used to execute any kind of pen test.

Wireshark: This tool can analyse actual network protocols and data packets. You can detect any weakness in the network in real-time. Here, live information and data can be collected from Bluetooth, Token ring, Kerberos, WEP, any Ethernet based connections, etc.

John The Ripper (JTR): One of the biggest cyber security threats is the inherent weakness of the traditional password. JTR is mainly used to provide database security. It can be used to pen test password databases that are in online and offline mode.

Kali Linux: This advanced pen testing software is available only on Linux machines. Many experts believe that this is the best tool for both injection and password sniffing. Kali is optimised every way for a penetration tester. Open testers commonly use Kali virtual machines on OSX or Windows.

Hashcat: This is the world's fastest and most advanced password recovery utility tool. It detects many kinds of password-guessing based brute force attacks, including dictionary and mask attacks.